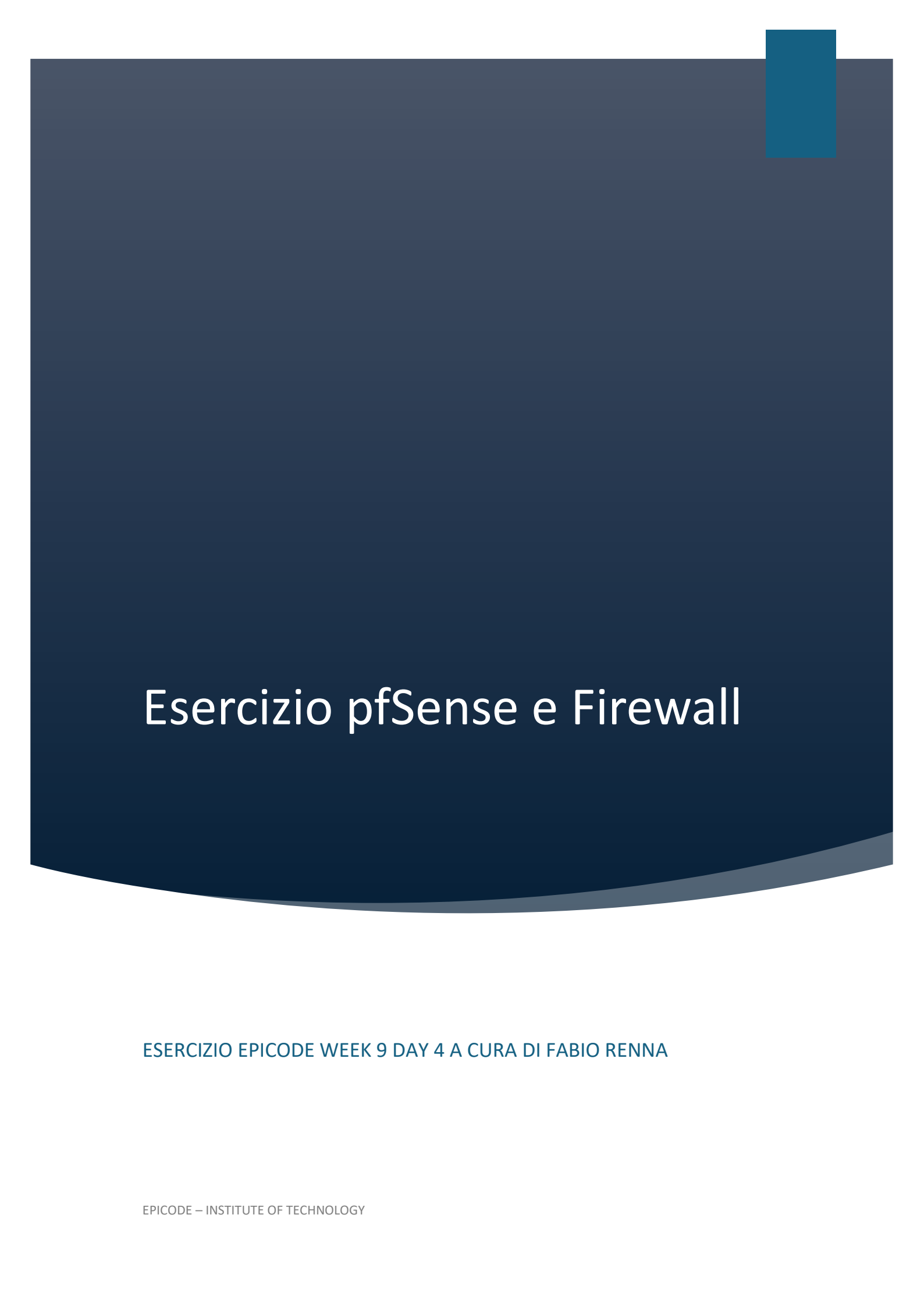




Esercizio pfSense e Firewall

ESERCIZIO EPICODE WEEK 9 DAY 4 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	2
Proof of Concept.....	3-9
Conclusione.....	10

Executive Summary

In questo report viene documentata la configurazione di un ambiente virtuale di laboratorio composto da pfSense, Kali Linux, Windows e Metasploitable2. L'obiettivo dell'attività è stato configurare pfSense come firewall e router interno, separare le reti di Kali e Metasploitable2 e creare una regola firewall che blocchi l'accesso HTTP (porta 80) alla DVWA da parte della macchina Kali.

Il Proof of Concept ha dimostrato che:

1. Kali può accedere normalmente ai servizi di Metasploitable prima dell'applicazione della regola;
2. dopo la regola di pfSense l'accesso viene filtrato/bloccato con successo.

Introduzione

Lo scopo di questo esercizio è comprendere il funzionamento di pfSense come firewall e router in un ambiente di laboratorio per attività di penetration testing. La segmentazione della rete e il filtraggio del traffico sono fondamentali per simulare scenari reali di sicurezza e controllare l'esposizione dei servizi vulnerabili (come DVWA).

Obiettivo

L'obiettivo dell'esercitazione è:

1. Installare pfSense in VirtualBox e configurare due reti interne (LAN e LAN2).
2. Assegnare
 - o Kali e Windows alla rete **192.168.50.0/24 (LAN)**
 - o Metasploitable2 alla rete **192.168.51.0/24 (LAN2)**.
3. Verificare la connettività tra i sistemi.
4. Creare una regola firewall che **blocchi l'accesso HTTP (porta 80)** da Kali verso DVWA su Metasploitable2.
5. Dimostrare, tramite scansioni e tentativi di accesso, che la regola funziona.

Proof of Concept

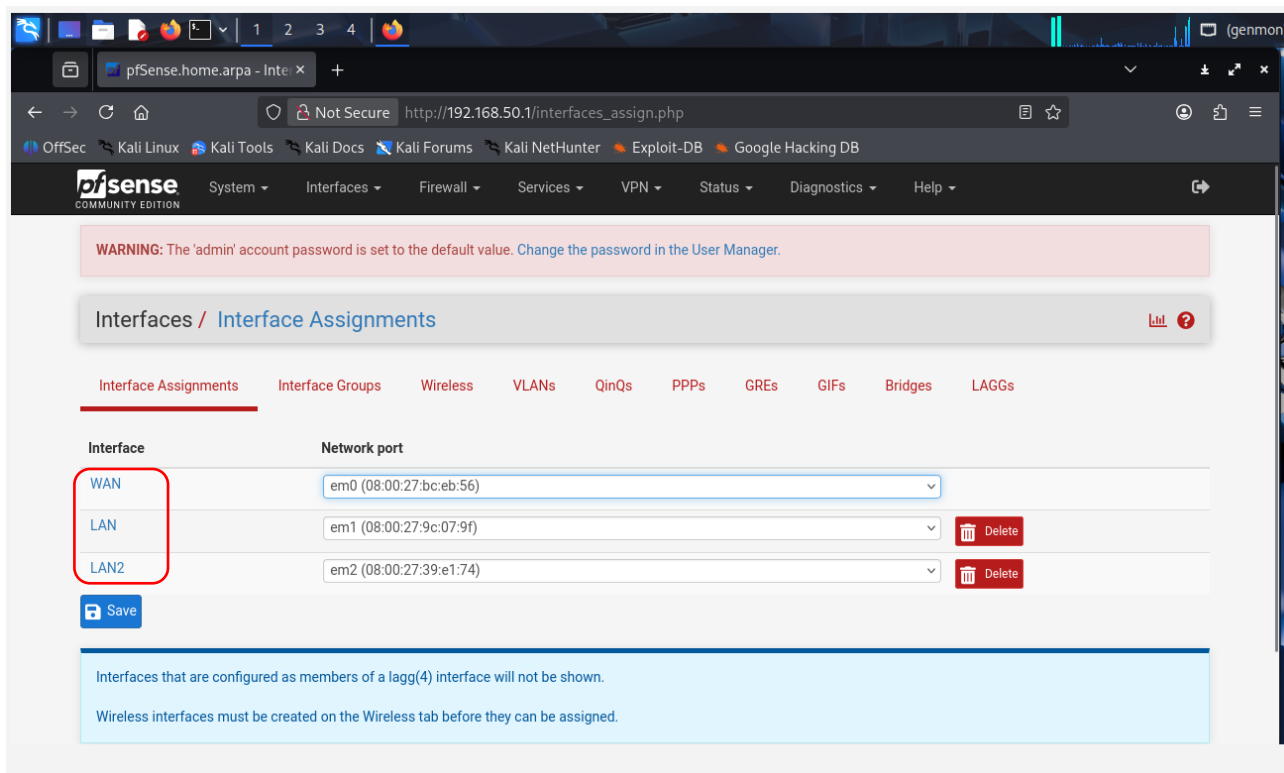
1. Verifica della corretta configurazione delle interfacce pfSense

Dopo l'installazione di pfSense, sono state configurate tre interfacce:

- **em0** - WAN (collegata in Bridge per accedere a Internet)
- **em1** - LAN associata alla rete interna *LABint* (192.168.50.0/24)
- **em2** - LAN2 associata alla rete *LABint2* (192.168.51.0/24)

Nella dashboard di pfSense (menu *Interfaces* → *Assignments*) è stata verificata la corretta associazione delle schede virtuali.

Successivamente, nell'interfaccia **LAN2** è stato assegnato l'IP statico 192.168.51.1/24, che fungerà da gateway e router per la rete dove risiede Metasploitable2.



2. Configurazione IP manuale su Metasploitable2

Metasploitable2, dopo essere stata collegata alla rete interna *LABint2*, non possedeva un IP valido.

È stato quindi configurato manualmente l'indirizzo IP e la netmask tramite: **`sudo ifconfig eth0 192.168.51.101 netmask 255.255.255.0 up`**

Un secondo comando ifconfig ha confermato:

- IP corretto: **192.168.51.101**
- MAC address coerente con la scheda virtuale
- Interfaccia attiva e funzionante

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.51.101 netmask 255.255.255.0 up
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:a4:fe:c7
          inet addr:192.168.51.101  Bcast:192.168.51.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fea4:fec7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:29 errors:0 dropped:0 overruns:0 frame:0
          TX packets:73 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1856 (1.8 KB)  TX bytes:8998 (8.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:151 errors:0 dropped:0 overruns:0 frame:0
          TX packets:151 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:48285 (47.1 KB)  TX bytes:48285 (47.1 KB)

msfadmin@metasploitable:~$ _
```

3. Verifica della connettività tra le due reti tramite pfSense

Da Kali (rete LABint) è stato eseguito un ping verso Metasploitable2: **`ping 192.168.51.101`**

Il ping ha avuto esito positivo, dimostrando che:

- La rotta tra LAN - LAN2 era correttamente gestita da pfSense
- Il traffico ICMP era consentito di default tramite le regole preconfigurate

```
(kali㉿kali)-[~]
$ ping 192.168.51.101
PING 192.168.51.101 (192.168.51.101) 56(84) bytes of data.
64 bytes from 192.168.51.101: icmp_seq=1 ttl=63 time=15.8 ms
64 bytes from 192.168.51.101: icmp_seq=2 ttl=63 time=2.61 ms
64 bytes from 192.168.51.101: icmp_seq=3 ttl=63 time=9.64 ms
64 bytes from 192.168.51.101: icmp_seq=4 ttl=63 time=7.76 ms
^C
— 192.168.51.101 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3052ms
rtt min/avg/max/mdev = 2.608/8.954/15.814/4.723 ms
```

4. Scansione della porta 80 su Metasploitable2 prima del blocco

Prima di applicare qualsiasi regola firewall, è stata eseguita una scansione da Kali verso Metasploitable2: **`nmap -p 80 192.168.51.101`**

Risultato:

- **Porta 80/tcp: OPEN**
- Servizio identificato: **HTTP**

Questo conferma che il servizio web di Metasploitable2 (che include DVWA) è raggiungibile dalla rete di Kali.

```
(kali㉿kali)-[~]
$ nmap -p 80 192.168.51.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-23 03:28 EST
Nmap scan report for 192.168.51.101
Host is up (0.0044s latency).

PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 13.19 seconds
```

5. Accesso a DVWA tramite browser

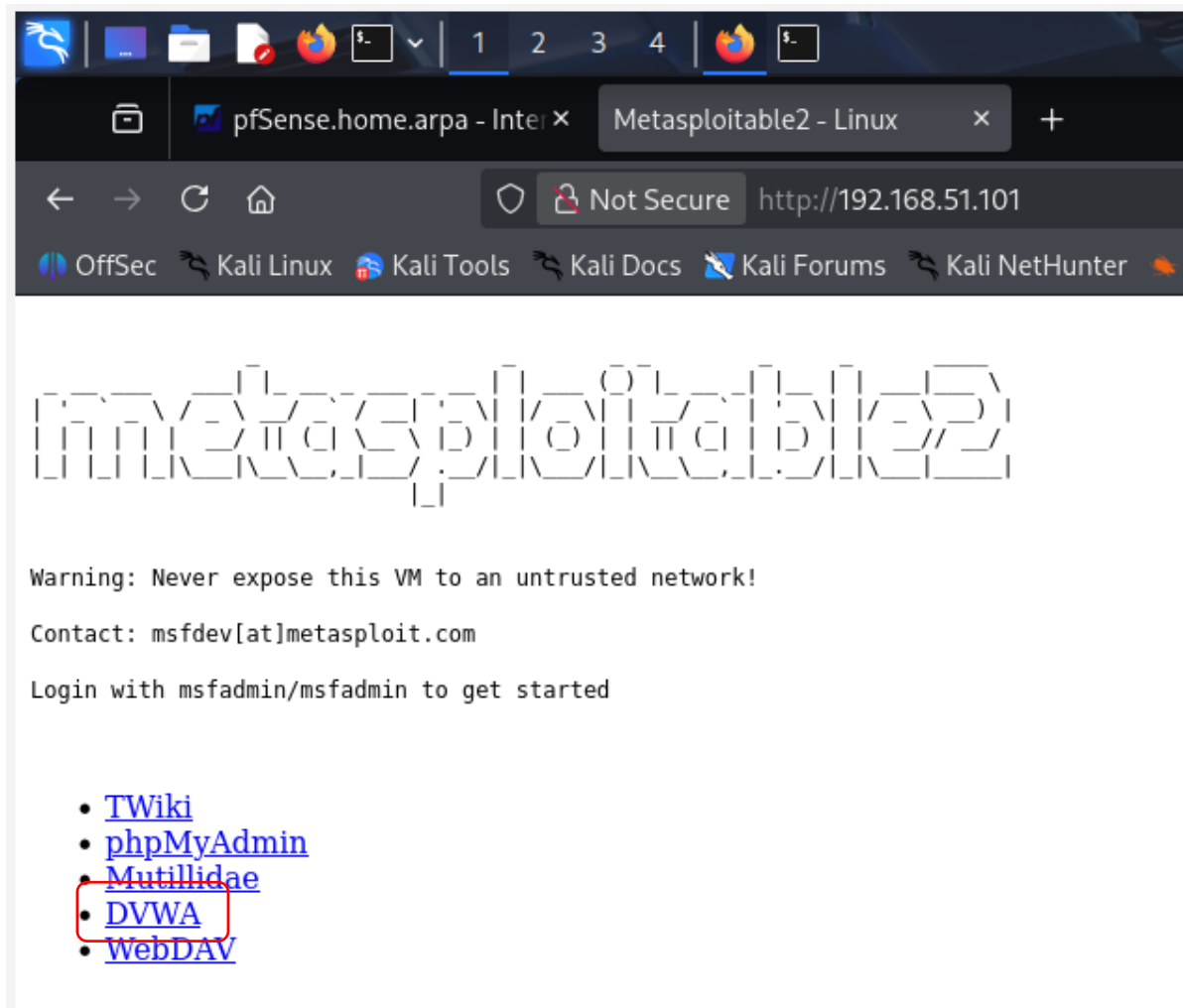
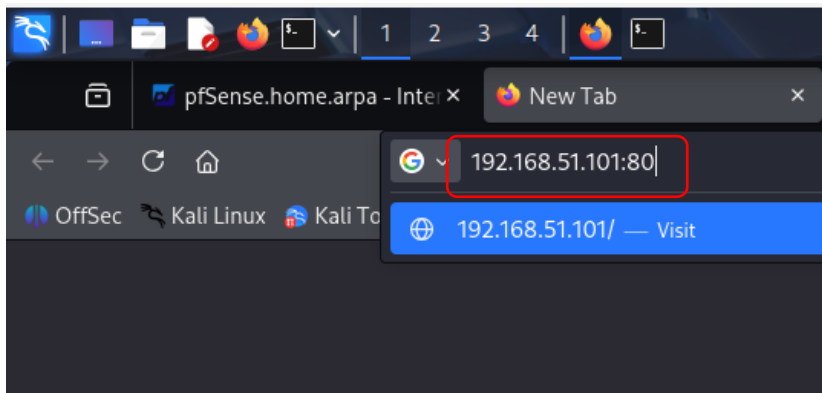
Per ulteriore conferma, da Kali è stato aperto Firefox e inserito: **`192.168.51.101:80`**

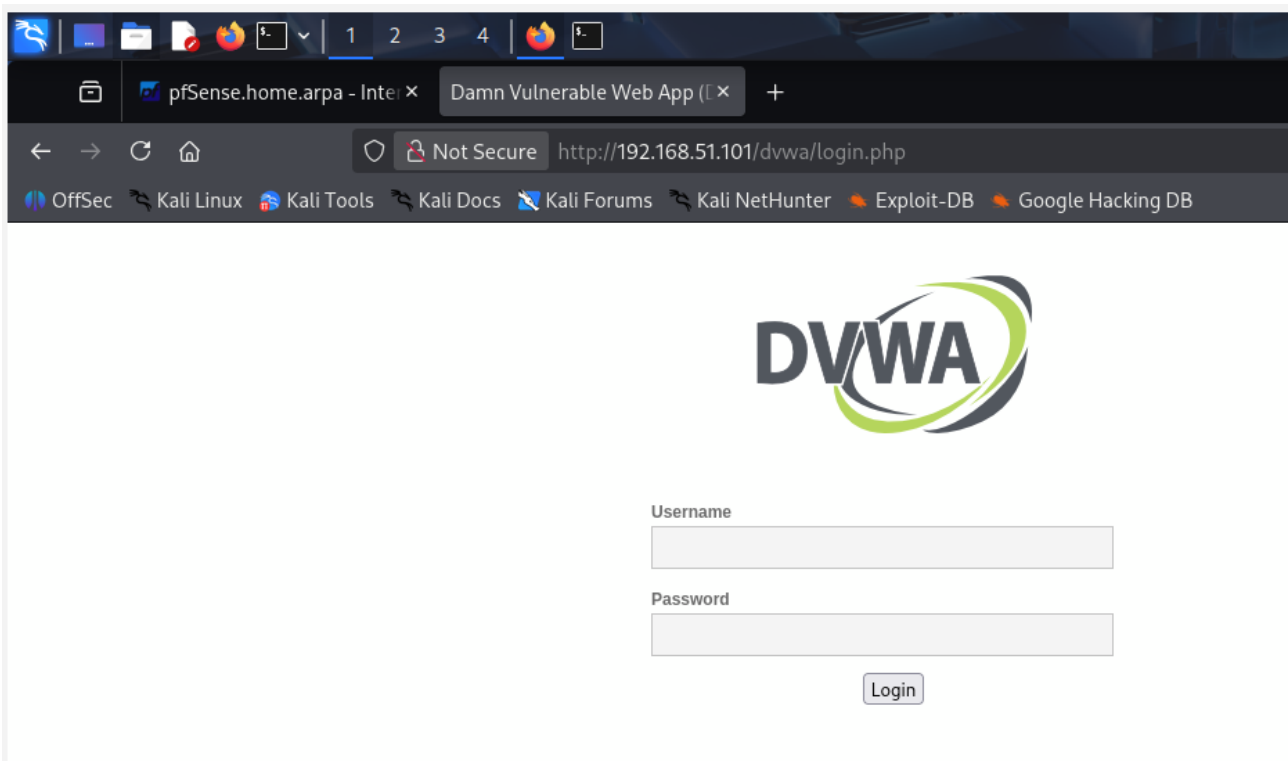
Si è visualizzata correttamente:

- La homepage di Metasploitable2
- I link ai servizi vulnerabili, tra cui **DVWA**

- La pagina di login di DVWA all'indirizzo:
<http://192.168.51.101/dvwa/login.php>

Questa fase conferma che, senza regole firewall, Kali può accedere liberamente a DVWA.





6. Creazione della regola firewall di blocco su pfSense

È stata quindi creata la regola specifica per bloccare **solo** l'accesso HTTP di Kali verso Metasploitable2.

Dal menu pfSense:

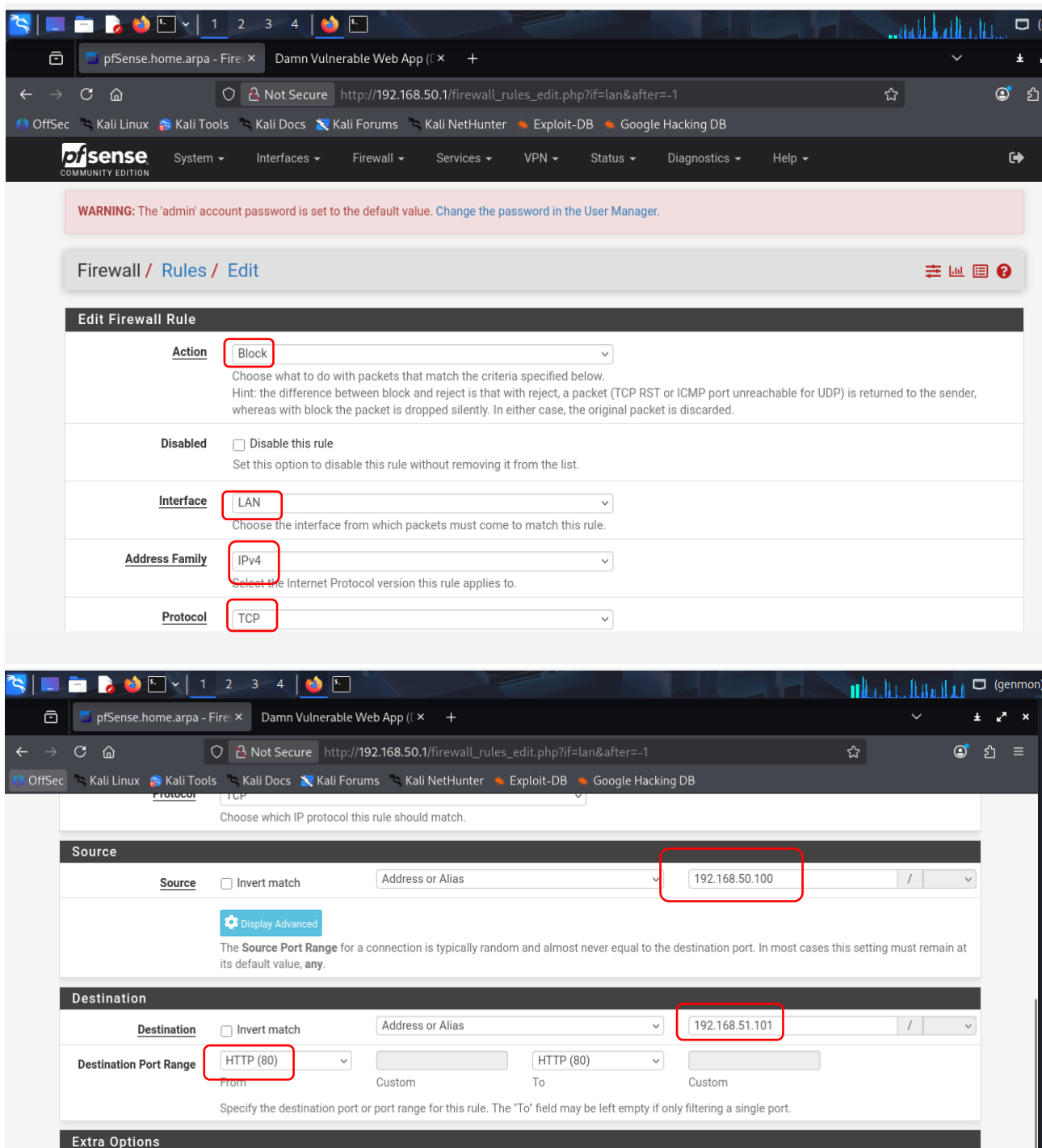
Firewall - Rules - LAN - Add new rule

La regola è stata configurata come segue:

- **Action:** Block
- **Interface:** LAN (rete da cui proviene l'attacco)
- **Protocol:** TCP
- **Source:** 192.168.50.100 (IP di Kali)
- **Destination:** 192.168.51.101 (IP di Metasploitable2)
- **Destination Port:** HTTP (80)

La regola è stata salvata e applicata ("Apply Changes").

L'ordine della regola nella tabella è stato verificato per assicurare che fosse sopra la regola di *allow all* predefinita della LAN.



7. Verifica del blocco tramite Nmap

Una nuova scansione da Kali ha mostrato: **`nmap -p 80 192.168.51.101 → 80/tcp filtered http`**

Il cambio di stato da **open** → **filtered** conferma che pfSense sta intercettando il traffico TCP verso la porta 80 e lo sta bloccando.

```
(kali㉿kali)-[~]
$ nmap -p 80 192.168.51.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-23 03:33 EST
Nmap scan report for 192.168.51.101
Host is up (0.0040s latency).

PORT      STATE      SERVICE
80/tcp    filtered  http

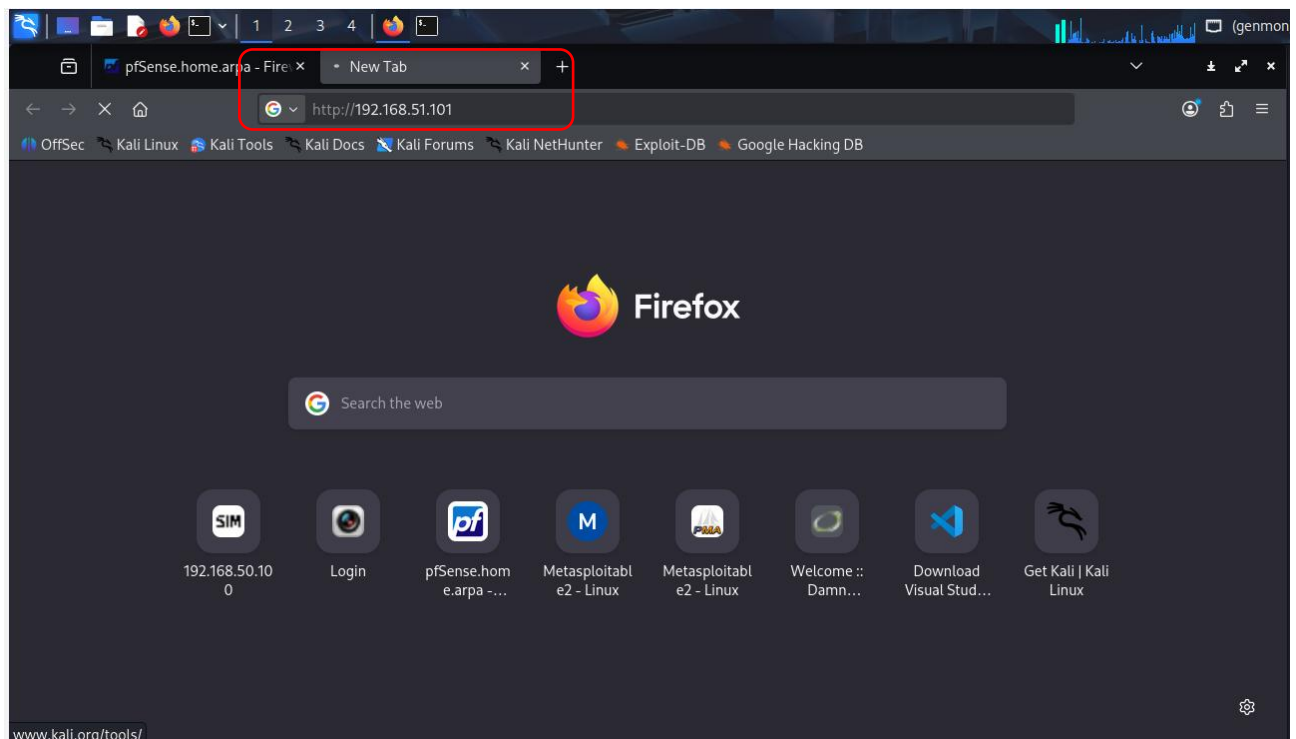
Nmap done: 1 IP address (1 host up) scanned in 13.38 seconds
```

8. Tentativo di accesso via browser dopo il blocco

Dopo aver applicato la regola, tentando di visitare, il browser non riesce più a caricare la pagina. La connessione resta in attesa e termina con errore.

Questo dimostra il successo del firewall nel bloccare:

- L'accesso HTTP
- Proveniente SOLO da Kali
- Destinato SOLO a Metasploitable2
- Senza interferire con ping, DNS o altra connettività di rete



Conclusione

L'esercitazione ha dimostrato con successo il funzionamento di pfSense nel controllare e limitare il traffico tra segmenti di rete differenti. La regola configurata ha impedito alla macchina Kali di accedere alla DVWA sulla macchina Metasploitable2, pur mantenendo la raggiungibilità a livello ICMP.

Questo dimostra che pfSense può essere utilizzato efficacemente per:

- Segmentare reti interne
- Limitare l'esposizione di host vulnerabili
- Applicare controlli granulari sul traffico
- Simulare scenari realistici di sicurezza per esercitazioni e formazione

Venezia, 21/11/2025

Fabio Renna